Xác thực hai bước (2FA) với Google Authenticator

Finance Manage – cách hoạt động và lưu ý khi chạy trên localhost

1. Tóm tắt

- 2FA là tính năng **tuỳ chọn**: mặc định tắt, người dùng tự bật trong Cài đặt → Bảo mật khi muốn; không bật thì đăng nhập chỉ cần email + mật khẩu (hoặc Google).
- 2FA của backend là chuẩn **TOTP** (RFC 6238): mã **6 số**, đổi mỗi **30 giây**, thuật toán HMAC-SHA1. Dùng được với **Google Authenticator**, Microsoft Authenticator, Authy, 1Password…
- Tính năng **chạy được trên localhost**, không cần đưa lên server: backend và app Authenticator không bao giờ liên lạc với nhau và cũng không gọi tới Google.
- Điều kiện duy nhất: đồng hồ của máy chạy backend và của điện thoại phải gần khớp nhau (lệch dưới khoảng 30 giây).

2. Cách hoạt động

Bước	Điều gì xảy ra
1. Thiết lập	App gọi `POST /api/v1/me/2fa/setup`. Backend tạo một **mã bí mật** (`secret`) và trả về chuỗi `otpauth://totp/FinanceManage:…` để hiển thị thành mã QR.
2. Thêm vào Authenticator	Quét QR bằng Google Authenticator, hoặc chọn **“Nhập khoá thiết lập”** và gõ chuỗi `secret`. Mã bí mật được lưu trong điện thoại.
3. Bật 2FA	Nhập mã 6 số đang hiện trong Authenticator vào `POST /api/v1/me/2fa/enable`. Backend trả về **10 mã khôi phục** dùng một lần – chỉ hiển thị một lần duy nhất.
4. Đăng nhập sau đó	`POST /auth/login` trả `twoFactorRequired: true` kèm `challengeToken` (hết hạn sau 5 phút). App gọi `POST /auth/2fa/verify` với mã từ Authenticator hoặc một mã khôi phục.
5. Kiểm tra mã	Cả backend và điện thoại **tự tính** mã từ cùng mã bí mật + giờ hiện tại. Backend chấp nhận lệch một bước (khoảng ±30 giây). Nhập sai 5 lần thì phải đăng nhập lại từ đầu.

Vì việc tính mã chỉ dựa vào mã bí mật và thời gian, điện thoại có thể không có mạng; Authenticator vẫn sinh mã bình thường.

3. Lưu ý khi test trên localhost

Điểm cần chú ý	Chi tiết
Giờ phải đúng	Bật “Đặt giờ tự động” trên máy tính và điện thoại. Lệch giờ là nguyên nhân phổ biến nhất khiến mã bị báo sai (`INVALID_CODE` / `INVALID_CREDENTIALS`).
Quét QR trên emulator	Emulator không có camera thật để quét. Cách dễ nhất: trong Google Authenticator chọn “Nhập khoá thiết lập” và gõ chuỗi `secret` mà màn hình 2FA hiển thị.

Điểm cần chú ý	Chi tiết
Không dùng điện thoại	Có thể sinh mã ngay trên máy tính bằng `oathtool --totp -b <secret>` (macOS: `brew install oath-toolkit`; Ubuntu: `sudo apt install oathtool`).
Mã khôi phục	Lưu lại 10 mã khôi phục khi bật 2FA, để test luồng "Dùng mã khôi phục" và để vào lại tài khoản nếu mất app Authenticator. Mỗi mã chỉ dùng được một lần.
Khoá mã hoá `ENCRYPTION_KEY`	Mã bí mật 2FA được mã hoá trong CSDL bằng khoá này. Local dùng khoá mặc định nên không sao; nhưng nếu đổi khoá, tài khoản đã bật 2FA sẽ không đăng nhập bằng 2FA được nữa.
Xoá CSDL dev	Xoá file devdb (H2) hoặc volume Postgres thì tài khoản mất; mục cũ trong Authenticator trở nên vô dụng. Xoá mục đó rồi bật lại 2FA cho tài khoản mới.
Mỗi lần setup tạo mã mới	Gọi lại `/me/2fa/setup` trước khi bật sẽ tạo mã bí mật mới; hãy dùng mục Authenticator ứng với lần setup gần nhất.

4. Thử nhanh bằng curl trên localhost

Đăng nhập trước để có access token trong biến `$TOKEN` (backend chạy ở `http://localhost:8080`).

Bước 1 – lấy mã bí mật:

```
curl -s -X POST localhost:8080/api/v1/me/2fa/setup \
  -H "Authorization: Bearer $TOKEN" | jq
```

Bước 2 – bật 2FA bằng mã hiện tại (thay `<secret>` bằng giá trị ở bước 1):

```
curl -s -X POST localhost:8080/api/v1/me/2fa/enable \
  -H "Authorization: Bearer $TOKEN" -H "Content-Type: application/json" \
  -d "{\"code\":\"$(oathtool --totp -b <secret>)\"}" | jq
```

Kết quả là danh sách 10 mã khôi phục. Từ lần đăng nhập sau, `/auth/login` trả `twoFactorRequired: true`.

Bước 3 – đăng nhập qua 2FA:

```
# 1) sign in: the response contains challengeToken
curl -s -X POST localhost:8080/api/v1/auth/login \
  -H "Content-Type: application/json" \
  -d '{"email":"<email>","password":"<password>"}' | jq

# 2) send the current 6-digit code with that challengeToken
CODE=$(oathtool --totp -b <secret>)
curl -s -X POST localhost:8080/api/v1/auth/2fa/verify \
  -H "Content-Type: application/json" \
  -d "{\"challengeToken\":\"<challengeToken>\",\"code\":\"$CODE\"}" | jq
```

5. Xử lý sự cố thường gặp

Hiện tượng	Nguyên nhân / cách xử lý
Mã luôn bị báo sai	Giờ máy tính hoặc điện thoại lệch. Bật đồng bộ giờ tự động; trong Google Authenticator có thể dùng mục "Đồng bộ thời gian cho mã" (Android).
Đúng mã nhưng vẫn lỗi sau nhiều lần thử	Đã nhập sai 5 lần, `challengeToken` hết hiệu lực, hoặc đã quá 5 phút. Đăng nhập lại để lấy challenge mới.
Mất điện thoại / xoá app Authenticator	Đăng nhập bằng một **mã khôi phục** thay cho mã 6 số, rồi tắt 2FA (`POST /me/2fa/disable`) và bật lại với điện thoại mới.
`TWO_FACTOR_NOT_SET_UP`	Gọi `/me/2fa/enable` khi chưa gọi `/me/2fa/setup`.
`TWO_FACTOR_ALREADY_ENABLED`	Tài khoản đã bật 2FA; muốn đổi điện thoại thì tắt rồi bật lại.

6. Khi đưa lên production

> **Đặt** `ENCRYPTION_KEY` **cố định (≥ 32 ký tự) và cất giữ ngoài server** – mất hoặc đổi khoá thì người dùng đã bật 2FA không qua được bước 2FA. Khoá này cũng cần khi khôi phục bản backup (xem `docs/DEPLOYMENT.md`).

- Server dùng đồng bộ giờ tự động (NTP) – mặc định trên các VPS Ubuntu.
- Không cần cấu hình gì thêm với Google: TOTP không dùng dịch vụ hay khoá API của Google.
- Tên hiển thị trong Authenticator là **FinanceManage** kèm email người dùng (cấu hình `app.identity.two-factor.issuer`).